

CYBER SECURITY ATTACKS

WAQAS JAMIL
21101009-015
MSCS 3RD

INTRODUCTION:

Information security, Network security and Cyber security are terms which can be used interchangeably. It is actually the protection of computer systems including hardware and software and networks from unauthorized access. It is also protection from information theft, disclosure and misdirecting any information that an organization provides. It is in fact used to protect your data from theft, damage and manipulation.

“A cyber security attack is an attempt to disable computers, steal data, or use a breached computer system to launch additional attacks. Cybercriminals use different methods to launch a cyber attack.”[1]

Following are the different types of security attacks

1. Malware Attacks
2. Social Engineering Attacks
3. Men in Middle Attacks
4. Denial of Service Attacks
5. Injections Attacks
6. Supply Chain Attacks

REASONS FOR CYBER SECURITY ATTACKS:

1. Money:

People are motivated towards committing cyber attacks is to make quick and easy money.

2. Revenge:

Some people try to take revenge with other person/organization/society/ caste or religion by damaging their reputation.

3. Fun:

The unprofessional or beginners commit cyber attacks for fun. They just want to check their skill or any tool.

4. Appreciation:

It is considered to be appreciation and pride if someone hacks any renowned or highly secured networks.

1. MALWARE ATTACKS:

Malware (short for “malicious software”) is a file or code, typically delivered over a network, that infects, explores, steals or conducts virtually any behavior an attacker wants.

Ransomware: Ransomware is a type of malware from crypto virology that threatens to publish the victim's personal data or permanently block access to it unless a ransom is paid off. While some simple ransomware may lock the system without damaging any files, more advanced malware uses a technique called crypto viral extortion.

Crypto jacking: Crypto jacking is a cybercrime in which another party's computing resources are hijacked to mine cryptocurrency. Crypto jacking, which is also referred to as malicious crypto mining, lets hackers mine cryptocurrency without paying for electricity, hardware and other mining resources.

Spyware: Spyware is software with malicious behavior that aims to gather information about a person or organization and send it to another entity in a way that harms the user

Adware: Adware is a form of malware that hides on your device and serves you advertisements. Some adware also monitors your behavior online so it can target you with specific ads. It attacks on privacy.

Fileless malware: Fileless malware is a type of malicious software that uses legitimate programs to infect a computer. It does not rely on files and leaves no footprint, making it challenging to detect and remove. It is usually part of OS which hijacks its kernel and modifies it.

Rootkit: A rootkit is a collection of computer software, typically malicious, designed to enable access to a computer or an area of its software that is not otherwise allowed and often masks its existence or the existence of other software.

2. SOCIAL ENGINEERING:

In the context of information security, social engineering is the psychological manipulation of people into performing actions or exposing confidential information. A type of confidence trick for the purpose of information gathering, fraud, or system access. It is about to manipulate socially.

Phishing: Phishing works by sending messages that look like they are from a legitimate company or website. Phishing messages will usually contain a link that takes the user to a fake website that looks like the real thing. The user is then asked to enter personal information, such as their credit card number.

Vishing: It is phishing through voice. The fraudulent practice of making phone calls or leaving voice messages claiming to be from reputable companies in order to induce individuals to reveal personal information, such as bank details and credit card numbers.

Smishing: it is phishing through SMS. the fraudulent practice of sending text messages claiming to be from reputable companies in order to induce individuals to reveal personal information, such as passwords or credit card numbers.

Piggybacking: A Piggyback attack is an active form of monitoring where the attacker gains access to a system via intervals of inactivity in another user's legitimate connection. It is also called a "between the line attack".

Tailgating: Tailgating attacks happen when someone with malicious intent enters a restricted area by piggybacking on an authorized employee. The employee is unaware of the attacker's plan but somehow becomes an accomplice to the crime.

3. MAN IN MIDDLE:

Also known as in cryptography and computer security, a man-in-the-middle, monster-in-the-middle, machine-in-the-middle, monkey-in-the-middle, meddler-in-the-middle, manipulator-in-the-middle. A man-in-the-middle (MitM) attack is a type of cyber attack in which the attacker secretly intercepts and spreads messages between two parties who believe they are communicating directly with each other.

WIFI Eavesdropping: Also known as an "evil twin" attack, hackers perform Wi-Fi eavesdropping is a type of man-in-the-middle attack that tricks unsuspecting victims into connecting to a malicious Wi-Fi network.

Email hijacking: Email hijacking is another form of man-in-the-middle attack, in which the hacker compromises and gain access to a target's email account. The attacker then silently monitors the communications between the client and the provider and uses the information for malicious purposes.

DNS Spoofing: DNS spoofing is an attack that uses altered Domain Name records to redirect traffic to a fraudulent site. DNS (Domain Name Service) spoofing is the process of poisoning entries on a DNS server to redirect a targeted user to a malicious website under attacker control.

IP Spoofing: In computer networking, IP address spoofing or IP spoofing is the creation of Internet Protocol packets with a false source IP address, for the purpose of imitating another computing system.

4. DENIAL OF SERVICE:

A Denial-of-Service (DoS) attack is an attack meant to shut down a machine or network, making it inaccessible to its intended users. DoS attacks accomplish this by flooding the target with traffic, or sending it information that triggers a crash. These attacks are applied on protocols and disable the services.

HTTP Flooding: A HTTP flood attack is a type of volumetric distributed denial-of-service (DDoS) attack designed to overwhelm a targeted server with HTTP requests. HTTP flood is a type of Distributed Denial of Service (DDoS) attack in which the attacker exploits seemingly-legitimate HTTP GET or POST requests to attack a web server or application.

Sync Flooding: A SYN flood is a form of denial-of-service attack in which an attacker rapidly initiates a connection to a server without finalizing the connection. The server has to spend resources waiting for half-opened connections, which can consume enough resources to make the system unresponsive to legitimate traffic.

UDP Flooding: A UDP flood is a type of denial-of-service attack in which a large number of User Datagram Protocol (UDP) packets are sent to a targeted server with the aim of overwhelming that device's ability to process and respond. The firewall protecting the targeted server can also become exhausted as a result of UDP flooding, resulting in a denial-of-service to legitimate traffic.

ICMP Flooding: An Internet Control Message Protocol (ICMP) flood DDoS attack, also known as a Ping flood attack, is a common Denial-of-Service (DoS) attack in which an attacker attempts to overwhelm a targeted device with ICMP echo-requests (pings). Normally, ICMP echo-request and echo-reply messages are used to ping a network device in order to diagnose the health and connectivity of the device and the connection between the sender and the device. By flooding the target with request packets, the network is forced to respond with an equal number of reply packets. This causes the target to become inaccessible to normal traffic.

5. SUPPLY CHAIN ATTACKS:

Supply chain attacks are an emerging kind of threat that target software developers and suppliers. The goal is to access source codes, build processes, or update mechanisms by infecting legitimate apps to distribute malware[10].

The software and their updates are signed and certified because software is created and distributed by reputable suppliers. Software suppliers are probably not aware that their software or updates contains malicious code. When they are made available to the general public, the malicious code then uses the same trust and accesses rights as the application.

with the popularity of several apps, there are a large number of possible victims. For example a free file compression program that was the most popular utility tool in the country was infected and distributed to users. There are different types of supply chain attacks.

- Compromised software building tools or updated infrastructure
- Stolen code-sign certificates or signed malicious apps using the identity of dev company
- Compromised specialized code shipped into hardware or firmware components
- Pre-installed malware on devices (cameras, USB, phones, etc.)[10]

6. INJECTION ATTACKS:

In this type of attacks, a piece of code is injected in running system to damage or manipulate data. The running system can be a program, a query or a computer to run such commands through which data can be altered or manipulated remotely on a web site or a database. After injecting infectious piece of code attacker intrudes into database or website to extract the required data. Injection attacks can be of different types including SQL injection, OS Command injection, Cross Site Scripting, LDAP injection and Code injection.

1. SQL Injection:

It is the most famous injection attack in which users are enforced to enter such data in textboxes through which attacker retrieves the data of his own requirement.

SQL injection is a security vulnerability that occurs in the database layers of an application. It is the act of passing SQL code into interactive web applications that employ in database services[2] It is a big threat for many companies operating online now a days because through it attackers can easily intercept into their database to collect the information about users, customers and monetary transactions. There are further three types of SQL injections.

- A.** In band SQL Injection: By using this type of SQL injection the information can be retrieved or sent back to attacker through the same channel that was implemented for attack.
- B.** Out of band SQL Injection: In this type of SQL injection information can be retrieved or sent back to attacker through a different channel such as email.
- C.** Inferential: This category is known as Blind injection, where an attacker does not depend on returning data from the server. However, attacker main goals are to reconstruct the data stored in the database by attempting to implement different attack and observe all the possible behavior from the server as well as the web application[3].

2. Operating System Command Injection:

It exploits websites by injecting an operating system command through an HTTP request to the web application[4]

It is the second type of injection attacks. It is usually used to upload a malware or retrieve a password. It is also called shell injection because in it attacker attacks the kernel or shell of an operating system and makes changes of his choice by executing a code.

Most programming languages include functions that let the developer call operating system commands. The reasons for calling operating system commands are varied, for example, to include functionality that is not available in that programming language by default, to call scripts written in other languages, and more. OS command injection vulnerabilities are a result of using such operating system call functions with insufficient input validation. A lack of validation enables the attacker to inject malicious commands into user input and then execute them on the host operating system[5].

3. Cross Site Scripting:

Cross-site scripting (also known as XSS) is a web security vulnerability that allows an attacker to compromise the interactions that users have with a vulnerable application. It allows an attacker to avoid the same origin policy, which is designed to segregate different websites from each other[6].

In Cross site scripting usually, an attacker presents himself as user and intercepts into system to perform any regular actions and tries to retrieve user's data. If that user has access in that system then attacker gains full control.

Cross-site scripting works by manipulating a vulnerable web site so that it returns malicious JavaScript to users. When the malicious code executes inside a victim's browser, the attacker can fully compromise their interaction with the application[6]. XSS attacks are most commonly committed attacks over the internet now a days because most of organizations are operating online and they rely heavily on web applications for storing their users and customers data and to make interaction with them.

Cross-cite scripting attacks ca be used to perform following malicious actions

- To remotely control the browser
- To spread worms
- To hijack an account

- To access browser history
- To access contents of clipboards[7]

4. LDAP Injection:

LDAP stands for Light Weight Directory Access Protocol. It is a common protocol used to make data and resources available for users. LDAP Injection is a cyber attack which falls under Injections category. Through it an attacker gains access over directories by passing such queries and causes data damage and theft.

In this type of attack, an attacker might modify LDAP statements using a local proxy in order to execute arbitrary commands (granting permissions to unauthorized queries) or modify the content of the LDAP tree[4].

LDAP uses queries constructed from predicates that involve the use of special characters (e.g., brackets, asterisks, ampersands, or quotes). Metacharacters such as these control the meaning of the query; thereby, affecting the type and number of objects retrieved from the underlying directory. If an attacker can submit input containing these control characters, they can alter the query and change the intended behavior[8].

LDAP injection is implemented on both server and client sides because these attacks occurs when a server does not confirm the authentication of a client requests. In such case attackers then easily communicate with LDAP servers. An LDAP injection attacks can cause the different cyber crimes such as Account Hijacking, Data Theft and Unauthorized Access.

LDAP is used in Microsoft's Active Directory, but can also be used in other tools such as Open LDAP, Red Hat Directory Servers and IBM Tivoli Directory Servers for example. Open LDAP is an open source LDAP application. It is a Windows LDAP client and admin tool developed for LDAP database control[9].